

ENGINEERING AND SECURITY REVIEW

Upsilon Platform Complete Code Audit Report

Repository-wide review of the company website, employee workspace, shared Express API, authentication, roles, leave, reimbursements, notifications, email, Careers, uploads, configuration, and scripts.

Audit date: 7 August 2026

Repository: `upsilon-platform`

Overall result: Mostly healthy, with confirmed high-impact issues corrected and several architecture-level risks documented.

Important: No environment secret values or credentials are included in this report.

1. Executive Summary

The repository contains two React/Vite applications: the public company website and the employee workspace. A shared Express/Mongoose backend provides employee, leave, reimbursement, notification, profile, team, holiday, Careers, and public website APIs. A separate legacy company website server also remains in the repository.

Build health
Both React production builds pass.

Backend syntax
All backend JavaScript files pass `node --check`.

Confirmed critical issues
No confirmed RCE or destructive data-loss issue.

Corrections
Security, authorization, data integrity, email, uploads, integration, and polling fixes applied.

The most important corrected problems were client-controlled reimbursement totals, invalid repeated reimbursement state transitions, public résumé exposure, inactive users retaining API access, role-attribution spoofing in leave status changes, known seed passwords, and missing reimbursement approval email to the applicant.

2. Application Map

Area	Technology	Responsibility
company-website/	React 19, Vite	Public website, resources, contact forms, public jobs, job applications, and two Careers-admin interfaces.
employee-workspace/frontend/	React 19, Vite, Axios	Employee, Team Leader, Manager, HR, Finance, and Admin workspace.
employee-workspace/backend/	Express 5, Mongoose, JWT, Nodemailer, Multer, Cloudinary	Shared API, authentication, data persistence, workflow enforcement, uploads, notifications, and email.
company-website/server/	Express, Nodemailer	Legacy standalone contact/resource server; it does not implement the newer Careers APIs.

Workspace authentication uses an HTTP-only JWT cookie. The API resolves the authenticated user from MongoDB on each protected request. Careers administrators use a separate scoped JWT cookie.

3. High-Priority Issues Corrected

HIGH Reimbursement amount manipulation

Problem: The backend accepted `subtotal` and `totalReimbursement` supplied by the browser.

Impact: An applicant could alter a network request and submit a value that did not match the expense items.

Fix: Every item, cost, date, business purpose, and cash advance is validated. Subtotal and final reimbursement are recalculated server-side.

HIGH Invalid and repeatable reimbursement transitions

Problem: TL, Manager/HR, and Finance endpoints did not consistently verify the current workflow state.

Impact: Requests could be approved or rejected repeatedly, generating duplicate history, email, and notifications. Finance could mark an invalid claim paid.

Fix: Added pending-state checks at each stage. Finance can mark paid only when the claim is finally approved and awaiting payment.

HIGH Inactive accounts retained access

Problem: JWT middleware loaded the user but did not reject `isActive: false`.

Impact: A deactivated user with an existing cookie remained authorized until token expiry.

Fix: Protected routes now return 403 immediately for inactive users.

HIGH Candidate résumés were public

Problem: Résumés were served from guessable `/uploads/resumes/...` URLs.

Impact: Anyone who obtained or guessed a filename could access candidate personal information.

Fix: Public résumé paths now return 404. Careers admins download through authenticated `GET /api/applications/:id/resume`.

HIGH Known privileged seed passwords

Problem: Admin, Finance, and Careers-admin scripts contained default passwords.

Impact: Running those scripts could create predictable privileged credentials.

Fix: Seed scripts require environment-provided passwords of at least eight characters. A repository scan found zero remaining known default-password matches.

HIGH Approver identity could be mislabeled

Problem: A Manager could choose “Approved by HR” and HR could choose “Approved by Manager” in manual status management.

Impact: Audit history and final status could misrepresent who made the decision.

Fix: The backend and frontend now expose only statuses attributable to the authenticated role.

4. Medium-Priority Issues Corrected

- Only Employee and Team Leader roles may submit leave or reimbursement requests.
- Final reimbursement approval now emails the applicant; rejection continues to email once.
- Reimbursement submission recipients are deduplicated and missing addresses are skipped.
- TL reimbursement rejection wording now clearly says “not recommended” and explains that Manager/HR makes the final decision.
- Career applications validate email addresses and allow only HTTP/HTTPS LinkedIn and portfolio links.
- Duplicate applications for the same job and email return HTTP 409.
- Email HTML now escapes user-controlled values, including names, purposes, statuses, and rejection reasons.
- Signature previews no longer hardcode localhost. Local `/uploads` requests are proxied by Vite.
- Signature upload is image-only and limited to 5 MB.
- Finance frontend routes now require authentication.
- Team listing is Admin-only at the backend.
- Production global 500 responses no longer expose internal error messages.
- The legacy website server no longer prints SMTP configuration values.
- Notification read attempts return 404 when the record is missing or not owned by the requester.
- The company website sticky contact button previously rendered nothing; its existing intended UI is restored.
- Finance leave search now reads the backend’s actual `finalStatus` property.

5. Authentication and Role Audit

Actual workspace roles are `Admin`, `HR`, `Manager`, `TeamLeader`, `Employee`, and `Finance`. Backend role checks are authoritative for the active Admin, leave, reimbursement, Finance, holiday, and team-management APIs.

Login normalizes email, compares a bcrypt hash, rejects inactive accounts, issues a seven-day HTTP-only JWT cookie, and avoids returning the password hash. Password changes validate the current password and require at least eight characters.

Remaining authentication/security concerns

- **CSRF:** Production authentication cookies use `SameSite=None`, but there is no CSRF-token mechanism.
- **Rate limiting:** Login, contact, resource-download, and public application endpoints have no brute-force or spam throttling.
- Several older controllers still return raw `error.message` values directly.
- Concurrent approval requests are protected by state checks but not by an atomic compare-and-update database operation.

6. Leave Workflow

1. An Employee submits leave. The assigned Team Leader, assigned Manager, and active HR users are notified and emailed.
2. The Team Leader records an advisory approval or non-recommendation. This is not a final decision.

3. The assigned Manager or HR makes the final approval/rejection under the existing alternative-final-approver design.
4. The applicant receives the in-app notification and final decision email.
5. Approved leave continues to notify and email Finance.

A Team Leader applying for personal leave skips TL self-review and proceeds to Manager/HR. Edited approved leave enters reapproval. Final email is not sent for intermediate TL action.

Concern left unchanged: The manual status endpoint can still place a request into a final state without reproducing every Finance side effect of the dedicated approve handler. Removing that capability could alter intended business behavior, so only role attribution was corrected.

7. Reimbursement and Finance Workflow

1. Employee or Team Leader submits a validated claim.
2. The server calculates monetary values from expense items.
3. TL review is advisory for Employee claims.
4. Manager or HR makes the final decision.
5. Applicant receives in-app and email notification.
6. Approved claims are routed to active Finance users.
7. Finance can mark paid only from the approved/pending-payment state.

Email failures are caught after database decisions and do not roll back successful workflow state.

8. Email and Notification Audit

Event	Recipients	Result
Leave submission	TL where applicable, assigned Manager, active HR	In-app + email
Final leave approval/rejection	Applicant	In-app + email
Approved leave	Finance	Existing notification/email preserved
Reimbursement submission	TL where applicable, assigned Manager, active HR	Deduplicated in-app + email
Final reimbursement approval/rejection	Applicant	In-app + email
Approved reimbursement	Finance	Existing notification/email preserved

The system uses Nodemailer over configured SMTP. `SMTP_FROM` is used as the sender with `SMTP_USER` as fallback. Outlook/Microsoft 365 is a recipient inbox, not a separate application integration.

9. Frontend–Backend API Audit

Verified obsolete mismatches

Frontend	Backend reality	Action
Dead <code>ApprovalRequests.jsx</code> : GET <code>/leave/pending</code> , PUT <code>/leave/approve/:id</code>	Active APIs are <code>/leave/tl-*</code> and <code>/leave/manager-*</code>	Not integrated because the component is not mounted.
Dead Attendance pages call <code>/attendance/*</code>	No attendance route/controller/model exists	No speculative attendance backend was created.
Résumé links used <code>/uploads/resumes/:filename</code>	Now authenticated by application ID	Fixed.

No unresolved endpoint mismatch was found in active leave, reimbursement, profile, notification, Admin, or current Careers screens.

10. Dead and Legacy Code

Verified unused workspace files

- `components/Navbar.jsx`
- `components/NotificationPanel.jsx`
- `pages/ApprovalRequests.jsx`
- `pages/Approvals.jsx`
- `pages/Attendance.jsx`
- `pages/AdminAttendanceReports.jsx`

Verified unused backend code

- `reportingRelationshipController.js`
- `ReportingRelationship.js`
- `utils/generateToken.js`

Two Careers admin implementations remain routed: the legacy `/careers-admin` interface and newer `/admin/careers` interface. They were not removed because both are reachable.

11. Performance and Polling

Recurring workspace API polling was removed from Dashboard statistics (30 seconds), reimbursement approvals (10 seconds), and Finance reimbursements (10 seconds). Initial loading, tab-driven loading, and post-action refreshes remain. The remaining interval is the intentional public website services carousel and includes cleanup.

Both frontend bundles exceed Vite's 500 kB recommendation. Route-level code splitting is a future optimization, not a correctness fix.

12. Files Modified

Company website: `server/server.js` ; Careers `ApplicantDetails.jsx` and `Applicants.jsx` ; `OurServicesSection.jsx` ; `SoftwareSection.jsx` ; `StickyContactButton.jsx` ; `WhyUpsilon.jsx` .

Backend: `app.js` ; career application/auth controllers and routes; leave, notification, and reimbursement controllers; authentication and upload middleware; profile and team routes; email service; Admin, Careers-admin, and Finance seed scripts.

Workspace frontend: `App.jsx` ; `SignatureUploader.jsx` ; Dashboard, Finance leave/reimbursement, Manager approvals, and reimbursement approvals pages; `vite.config.js` .

13. Verification Results

Command/check	Result	Notes
<code>npm run build</code> at repository root	PASS	Company website and workspace production builds passed.
Company <code>npm run lint</code>	PASS	Two Fast Refresh warnings remain.
Workspace <code>npm run lint</code>	FAIL	33 errors and 10 warnings, predominantly the React Hooks preset rejecting fetch-on-mount effects and findings in verified dead files. Rules were not disabled to manufacture a clean result.
Backend JavaScript <code>node --check</code>	PASS	All backend JavaScript files.
Legacy server syntax	PASS	<code>node --check server.js</code> .
<code>npm ls --depth=0</code>	PASS	All application dependency trees; workspace contains two extraneous transitive packages.
Email safety smoke test	PASS	Mocked delivery succeeded and injected HTML was escaped.
Automated backend/integration tests	NOT CONFIGURED	No test scripts exist.

14. Remaining Issues

- Workspace lint baseline is still non-clean.
- No automated unit, integration, or end-to-end tests are configured.
- The company package's standalone development command starts the legacy server, which lacks newer Careers APIs. The shared backend is required for complete functionality.
- Cloudinary files may become orphaned when upload succeeds but later controller validation fails.
- CSRF protection and public/auth rate limiting remain absent.
- Some controllers expose raw internal error messages.
- Approval transitions are guarded but not atomic against simultaneous duplicate requests.
- Dashboard statistics return broad organization totals; the intended role visibility was not clear enough to change safely.
- Legacy/current Careers implementations should eventually be consolidated.

15. Manual Testing Checklist

1. Log in as Employee, Team Leader, Manager, HR, Finance, and Admin.
2. Deactivate a logged-in user and confirm their next protected request returns 403.
3. Submit Employee leave; confirm TL, Manager, and HR notification/email.
4. Submit Team Leader personal leave; confirm Manager/HR notification without TL self-notification.
5. Approve and reject leave; confirm one applicant Outlook email with correct details.
6. Submit reimbursement; verify server total equals item costs minus cash advance.
7. Modify totals in browser DevTools and confirm the backend ignores them.
8. Repeat approve/reject/pay calls and confirm the second action is rejected.
9. Confirm Finance cannot pay pending or rejected claims.
10. Verify reimbursement applicant and Finance emails/notifications.
11. Submit a Careers application and confirm duplicate job/email submission is rejected.
12. Confirm public résumé URLs return 404 and Careers-admin download works.
13. Upload/remove a profile photo and upload an image signature.
14. Confirm PDF signature upload is rejected.
15. Verify contact/resource forms and sticky contact button.
16. Verify notification read and read-all behavior.
17. Log out, refresh, and confirm protected routes return to login.

This report records the repository state and verification performed during the audit. Environment values, passwords, SMTP credentials, database connection strings, and Cloudinary secrets are intentionally excluded.